

COREPLAN

Media Planning & Campaign Management

DOKUMENTACJA ETAPU 1

Architektura, Autentykacja, Model Danych, Frontend

Wersja 1.0 — Kwiecień 2026

Dokument 1 z 3

SPIS TREŚCI

1. Wprowadzenie i cel dokumentu
2. Mapa etapów projektu
3. Architektura systemu
4. Konfiguracja środowisk
5. Autentykacja i RBAC
6. Model danych i baza
7. Frontend — warstwa prezentacji
8. Edge Functions — logika serwerowa
9. Bezpieczeństwo
10. Podsumowanie Etapu 1

1. Wprowadzenie i cel dokumentu

Niniejszy dokument stanowi część pierwszą z trzech dokumentacji technicznych platformy CorePlan — kompleksowego systemu do zarządzania planowaniem mediów i kampaniami reklamowymi.

Etap 1 obejmuje fundamenty techniczne: architekturę systemu, konfigurację środowisk, system autentykacji z MFA, model uprawnień RBAC, schemat bazy danych oraz podstawową warstwę frontendową.

Informacje o produkcie

Nazwa produktu	CorePlan
Typ aplikacji	SPA (Single Page Application) — web-based
Architektura	Multi-tenant SaaS z izolacją RLS
Język interfejsu	Polski (pl-PL)
URL produkcyjny	https://coreplan-pl.lovable.app
Licencja	Proprietary / SaaS

2. Mapa etapów projektu

Projekt CorePlan jest realizowany w 3 etapach. Poniższa tabela prezentuje pełną mapę zakresu:

Etap	Zakres	Status	Dokument
Etap 1	Architektura, środowiska, autentykacja, RBAC, model danych, frontend	☑ Zrealizowany	Ten dokument
Etap 2	Logika biznesowa, workflow, integracje, email, backup, powiadomienia	⌚ W trakcie	Dokument 2/3
Etap 3	Panel super admin, raporty, eksport, optymalizacja, testy, deploy	📅 Planowany	Dokument 3/3

3. Architektura systemu

3.1 Przegląd architektury

CorePlan opiera się na architekturze multi-tenant SaaS z pełną izolacją danych na poziomie PostgreSQL Row Level Security (RLS). Każda firma (tenant) operuje w odizolowanym kontekście danych.

3.2 Stos technologiczny

Warstwa	Technologia	Zastosowanie
Frontend	React 18 + TypeScript 5	Biblioteka UI i typowanie statyczne
Bundler	Vite 5	Dev server i produkcyjny build
Styling	Tailwind CSS 3 + shadcn/ui	Utility CSS + komponenty Radix
State	TanStack Query 5	Cache, fetching, synchronizacja
Routing	React Router 6	Nawigacja SPA
Backend	Lovable Cloud (Supabase)	BaaS — baza, auth, storage, functions
Baza danych	PostgreSQL 15 + RLS	Relacyjna baza z izolacją tenantów
Auth	Supabase Auth	Email/password + MFA (TOTP)
Functions	Deno Edge Functions	Logika serwerowa
E-mail	Resend API	Maile transakcyjne i powiadomienia
Storage	Supabase Storage	Pliki: backupy, potwierdzenia

3.3 Architektura multi-tenant

Izolacja danych między firmami jest wymuszana na 3 poziomach:

- Kolumna `organization_id` w każdej tabeli biznesowej
- Polityki RLS (Row Level Security) sprawdzające przynależność użytkownika do organizacji
- Funkcje SECURITY DEFINER: `is_org_member()`, `get_org_role()`, `get_user_org_ids()`

Kluczowe tabele struktury tenantów:

- `organizations` — rejestr firm (tenantów)
- `organization_members` — powiązanie użytkowników z firmami + rola org
- `organization_clients` — mapowanie klientów do firm

4. Konfiguracja środowisk

4.1 Zmienne środowiskowe

Aplikacja korzysta z następujących zmiennych środowiskowych (zarządzanych automatycznie):

Zmienna	Opis
VITE_SUPABASE_URL	URL instancji backendu
VITE_SUPABASE_PUBLISHABLE_KEY	Klucz publiczny (anon key)
VITE_SUPABASE_PROJECT_ID	Identyfikator projektu
RESEND_API_KEY	Klucz API Resend (e-mail)
HOSTINGER_BACKUP_URL	Endpoint backupów Hostinger
HOSTINGER_BACKUP_KEY	Klucz autoryzacji backupów

4.2 Buckety storage

Bucket	Dostęp	Przeznaczenie
confirmations	Prywatny	Screeny potwierdzeń realizacji
backups	Prywatny	Kopie zapasowe bazy danych

5. Autentykacja i RBAC

5.1 Mechanizm autentykacji

System autentykacji oparty jest na Supabase Auth z następującymi mechanizmami:

- Rejestracja email/hasło z weryfikacją adresu e-mail
- Logowanie z obsługą MFA (Multi-Factor Authentication) — TOTP
- Dwupoziomowe AAL (Authenticator Assurance Level): aal1 → aal2
- Reset hasła przez link e-mail z przekierowaniem
- Zaproszenia: Super Admin zaprasza firmę, Org Admin zaprasza członków

5.2 Przepływ rejestracji

1. Super Admin tworzy organizację i wysyła zaproszenie do Org Admina
2. Org Admin otrzymuje e-mail z linkiem do ustawienia hasła
3. Org Admin loguje się i konfiguruje firmę (onboarding)
4. Org Admin zaprasza członków zespołu (Edge Function: create-org-member)
5. Członkowie otrzymują zaproszenie e-mail z nazwą firmy

5.3 Hierarchia ról (RBAC)

Rola	Uprawnienia	Zapis ról
super_admin	Pełny dostęp globalny: firmy, użytkownicy, logi, ustawienia	user_roles
org_admin	Zarządzanie własną firmą: użytkownicy, klienci, produkty	organization_members
manager	Edycja aktywności, klientów i produktów w firmie	organization_members
user	Tworzenie i edycja własnych aktywności	organization_members
viewer	Tylko odczyt danych firmy	organization_members

5.4 Funkcje bezpieczeństwa (SECURITY DEFINER)

System wykorzystuje dedykowane funkcje PostgreSQL do weryfikacji uprawnień:

- has_role(user_id, role) — sprawdza rolę globalną
- is_super_admin(user_id) — czy użytkownik jest super adminem
- is_org_member(user_id, org_id) — czy należy do organizacji
- get_org_role(user_id, org_id) — zwraca rolę w organizacji
- get_user_org_ids(user_id) — lista ID organizacji użytkownika
- validate_org_role_change() — trigger walidujący zmianę roli
- validate_super_admin_role() — tylko super_admin może nadać super_admin

6. Model danych i baza

6.1 Tabele biznesowe

Tabela	Opis	Kluczowe kolumny
organizations	Rejestr firm (tenantów)	name, slug, status, nip, email
profiles	Profile użytkowników	user_id, display_name, status
user_roles	Role globalne	user_id, role (enum app_role)
organization_members	Członkostwo w firmach	organization_id, user_id, org_role
clients	Klienci (rejestr globalny)	name, annual_budget, currency
organization_clients	Mapowanie klientów→firm	organization_id, client_id
products	Produkty	name, ean, brand, category
packages	Pakiety reklamowe	name, default_price, items (JSON)
activities	Aktywności reklamowe	name, channel, campaign_type, price
media_plans	Plany mediowe	name, year, version, client_id
confirmations	Dowody realizacji	activity_id, image_url, is_cover
campaign_types	Typy kampanii (per org)	name, label, organization_id

6.2 Tabele systemowe

Tabela	Opis	Kluczowe kolumny
system_logs	Logi systemowe	event_type, description, metadata
audit_log	Audit trail (INSERT/UPDATE/DELETE)	action, table_name, old_data, new_data
trash_registry	Centralny kosz (soft delete)	record_type, purge_at, restored_at
backup_history	Historia backupów	file_path, checksum, size_bytes
notifications	Powiadomienia in-app	title, type, category, is_read
app_settings	Ustawienia (per org)	key, value, organization_id
email_send_log	Log wysyłki e-maili	template_name, status, recipient
email_send_state	Stan kolejki e-mail	batch_size, send_delay_ms

6.3 Enum app_role

System definiuje następujące role jako PostgreSQL ENUM:

- admin — administrator systemu (legacy)
- super_admin — globalny administrator platformy
- org_admin — administrator organizacji
- manager — menedżer w organizacji
- user — standardowy użytkownik

- viewer — wyłącznie odczyt

7. Frontend — warstwa prezentacji

7.1 Struktura komponentów

Aplikacja zbudowana jest z modułowych komponentów React:

Komponent / Moduł	Odpowiedzialność
AppLayout + AppSidebar	Główny layout z nawigacją boczną i top barem
ProtectedRoute	Gating: auth, MFA, status profilu, onboarding
SuperAdminRoute	Dostęp wyłącznie dla super_admin
DashboardView	Dashboard firmowy z KPI i wykresami
ClientsView	Zarządzanie klientami firmy
ProductsView	Zarządzanie produktami i pakietami
YearView	Widok roczny aktywności (timeline)
ActivityDialog	Tworzenie/edycja aktywności
ReportsView	Raporty i analityka
SettingsView	Ustawienia firmy i profilu
NotificationCenter	Centrum powiadomień in-app
OnboardingDialog	Wizard onboardingowy
MfaSetup	Konfiguracja MFA/TOTP

7.2 Konteksty React

Kontekst	Odpowiedzialność
AuthContext	Sesja, logowanie/wylogowanie, MFA (AAL), reset hasła
OrganizationContext	Aktywna firma, tryb widoku, przełączanie kontekstu
AppContext	Stan biznesowy: klienci, aktywności, filtry, produkty

7.3 Custom Hooks

Aplikacja wykorzystuje dedykowane hooki React do separacji logiki:

- `useActivities` — CRUD aktywności z cache TanStack Query
- `useRole / useMyOrgRole` — rola użytkownika w kontekście organizacji
- `useProfileStatus` — status profilu (pending/active/rejected)
- `useNotifications` — powiadomienia in-app z realtime
- `useData` — główny hook danych biznesowych
- `useOrgMembers` — członkowie organizacji
- `useSuperAdmin` — logika panelu super admina

8. Edge Functions — logika serwerowa

System wykorzystuje Deno Edge Functions do operacji wymagających uprawnień `service_role`:

Funkcja	Opis
<code>create-org-member</code>	Tworzenie użytkownika w organizacji (invite flow)
<code>create-org-user</code>	Tworzenie konta przez Org Admin
<code>setup-super-admin</code>	Inicjalizacja super admina
<code>auth-email-hook</code>	Custom szablon e-mail (brandowane)
<code>send-notification-email</code>	Wysyłka e-mail przy nowym powiadomieniu
<code>process-email-queue</code>	Kolejka e-mail (PGMQ) z retry logic
<code>activity-workflow</code>	Automatyzacja workflow aktywności
<code>backup-to-hostinger</code>	Backup bazy na Hostinger
<code>scheduled-backup</code>	Automatyczny backup (cron)
<code>data-export</code>	Eksport danych (CSV/JSON)
<code>data-import</code>	Import danych
<code>purge-trash</code>	Czyszczenie kosza po 180 dniach
<code>send-demo-notification</code>	Powiadomienie o nowym zgłoszeniu demo

9. Bezpieczeństwo

9.1 Row Level Security (RLS)

Każda tabela w bazie danych posiada aktywne polityki RLS. Wzorce:

- Dostęp org: WHERE organization_id IN (get_user_org_ids(auth.uid()))
- Super admin bypass: WHERE is_super_admin(auth.uid())
- Własność: WHERE user_id = auth.uid()
- Dostęp per rola: get_org_role() = 'org_admin'

9.2 Zabezpieczenia dodatkowe

- MFA/TOTP — opcjonalne dwuskładnikowe uwierzytelnianie
- Trigger protect_profile_columns — blokuje zmianę user_id, id, created_at
- Trigger validate_org_role_change — tylko org_admin/super_admin zmienia rolę
- Trigger validate_super_admin_role — tylko super_admin nadaje tę rolę
- Audit log — pełny zapis INSERT/UPDATE/DELETE z old_data i new_data
- Soft delete — dane trafiają do kosza z możliwością przywrócenia (180 dni)
- E-mail suppression list — blokowanie wysyłki do nieaktywnych adresów

10. Podsumowanie Etapu 1

Etap 1 dostarcza kompletne fundamenty techniczne platformy CorePlan:

Element	Status	Uwagi
Architektura multi-tenant	☒ Gotowe	RLS + org isolation
Konfiguracja środowisk	☒ Gotowe	Auto-managed env vars
Autentykacja email/password	☒ Gotowe	Z weryfikacją e-mail
MFA (TOTP)	☒ Gotowe	Opcjonalne per user
System RBAC (5 ról)	☒ Gotowe	Global + per org
Model danych (20+ tabel)	☒ Gotowe	Z RLS na każdej
Frontend (komponenty)	☒ Gotowe	React + shadcn/ui
Edge Functions (13)	☒ Gotowe	Deno runtime
Audit log	☒ Gotowe	Pełny trail
System e-mail	☒ Gotowe	Resend + PGMQ

Koniec dokumentu Etapu 1

Następny: Etap 2 — Logika biznesowa, workflow, integracje